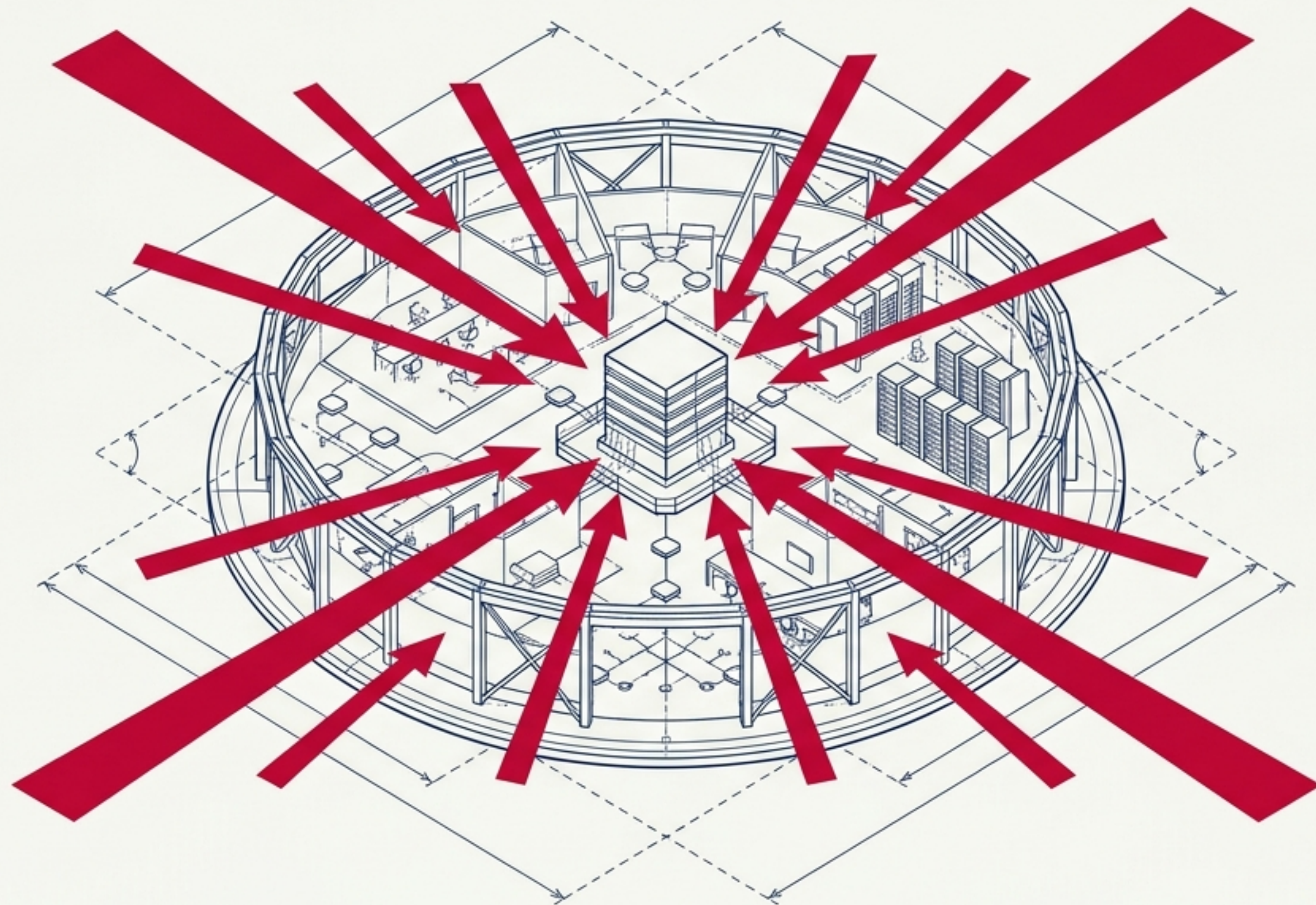




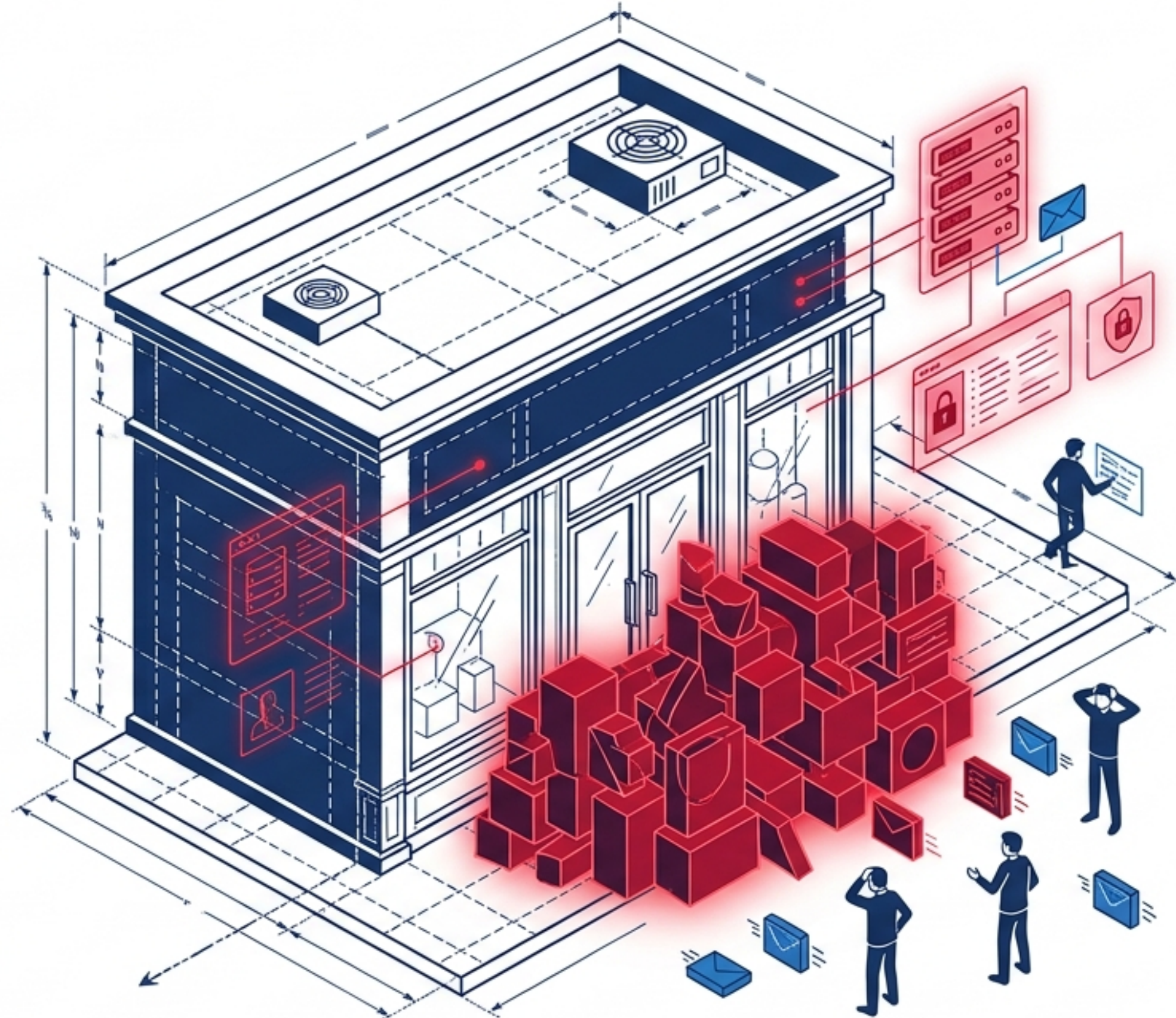
שדה הקרב האסימטרי: האנטומיה של מתקפות מניעת שירות (DDoS)

התפתחות, מכניקה ואסטרטגיות הגנה בעידן של לוחמת סייבר מבוזרת.



מהי מתקפת מניעת שירות?

מתקפת DoS
(Denial-of-Service)
נועדה להפוך משאב
רשת לבלתי זמין עבור
המשתמשים
הלגיטימיים שלו.



האנלוגיה המושלמת:

דמיינו המון מאורגן
החוסם לחלוטין דלת
כניסה של חנות.
לקוחות לגיטימיים
אינם יכולים להיכנס,
להיכנס, המסחר
נפסק, והעסק מפסיד
מפסיד כסף.

המטרה אינה לפרוץ למערכת או לגנוב נתונים, אלא הצפת
המערכת בבקשות סרק כדי להקריס או לשתק את משאביה.

מאיום נקודתי לנשק אסטרטגי גלובלי

ההיקף של מתקפות DDoS צומח בקצב אקספוננציאלי.

• **אוקטובר 2023:** ניצול פרוטוקול HTTP/2 Rapid Reset – גוגל סופגת מתקפת שיא של 398 מיליון בקשות בשנייה (rps).

• **2016:** עידן ה-TLo – הבוטנט Mirai מייצר תעבורה של מעל 1 Tbps ומשתק תשתיות אינטרנט מרכזיות.

• **1996:** התקרית הגדולה הראשונה – ספקית האינטרנט Panix קורסת תחת מתקפת SYN Flood של מגה-ביטים בודדים.

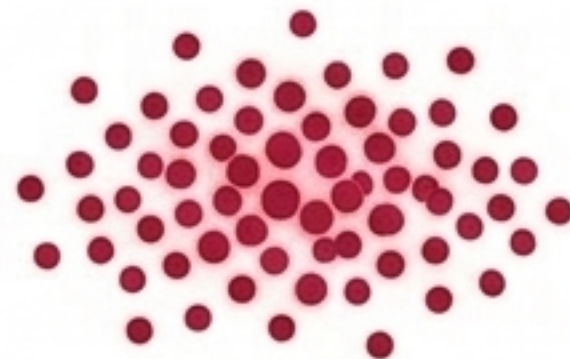
• **ספטמבר 2025:** חברת Cloudflare חוסמת חסימת מתקפה אדירה המגיעה לשיא של 22.2 Tbit/s ממעל 404,000 כתובות IP שונות.

סיווג איומים: DoS מול DDoS מול APDoS



[מתקפת DoS (מקור יחיד)]

- **מספר מקורות:** מחשב תוקף בודד או כתובת IP אחת. 
- **טקטיקה:** ניצול חולשות תוכנה ספציפיות או שליחת חבילות נתונים פגומות (לדוגמה: Ping of Death). 
- **הגנה:** קלה יחסית; ניתן לחסום בקלות את מקור התקיפה. 

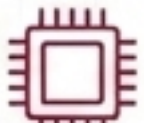


[מתקפת DDoS (מבוזרת)]

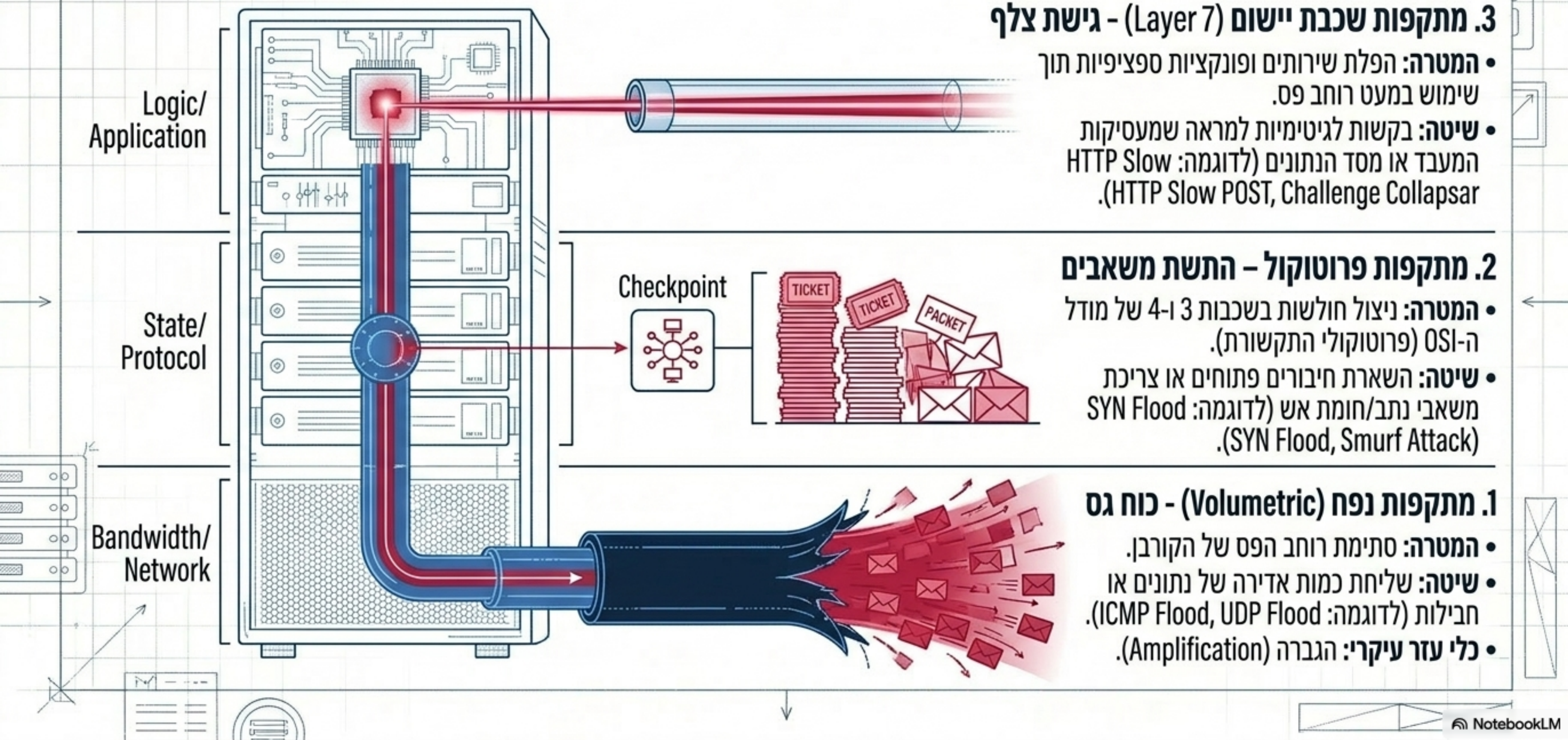
- **מספר מקורות:** אלפי או מיליוני מכשירים נגועים (Botnet). 
- **טקטיקה:** הצפת רוחב פס (Volumetric) או משאבי רשת ממספר רב של מוקדים בו-זמנית. 
- **הגנה:** קשה; דורשת סינון מורכב וניתוב תעבורה היות היות ולא ניתן לחסום כתובת יחידה. 



[מתקפת APDoS (מתקדמת ומתמשכת)]

- **מספר מקורות:** משאבי רשת עצומים ויכולת חישוב מאסיבית. 
- **טקטיקה:** החלפת יעדים טקטית, סיור מוזשית החזמימות, מודיעיני מוקדם (OSINT), ושילוב במקביל של שכבות רשת שונות (Layers 3-7). 
- **משך:** יכולה להימשך שבועות (תועדה מתקפה של 38 ימים עם תעבורה של למעלה מ-50 Petabits). 

שלוש החזיתות: כיצד התוקפים מכהים את המערכת?



3. מתקפות שכבת יישום (Layer 7) - גישת צלף

- **המטרה:** הפלת שירותים ופונקציות ספציפיות תוך שימוש במעט רוחב פס.
- **שיטה:** בקשות לגיטימיות למראה שמעסיקות המעבד או מסד הנתונים (לדוגמה: HTTP Slow (HTTP Slow POST, Challenge Collapsar).

2. מתקפות פרוטוקול - התשת משאבים

- **המטרה:** ניצול חולשות בשכבות 3 ו-4 של מודל ה-OSI (פרוטוקולי התקשורת).
- **שיטה:** השארת חיבורים פתוחים או צריכת משאבי נתב/חומת אש (לדוגמה: SYN Flood (SYN Flood, Smurf Attack).

1. מתקפות נפח (Volumetric) - כוח גס

- **המטרה:** סתימת רוחב הפס של הקורבן.
- **שיטה:** שליחת כמות אדירה של נתונים או חבילות (לדוגמה: ICMP Flood, UDP Flood (ICMP Flood, UDP Flood).
- **כלי עזר עיקרי:** הגברה (Amplification).

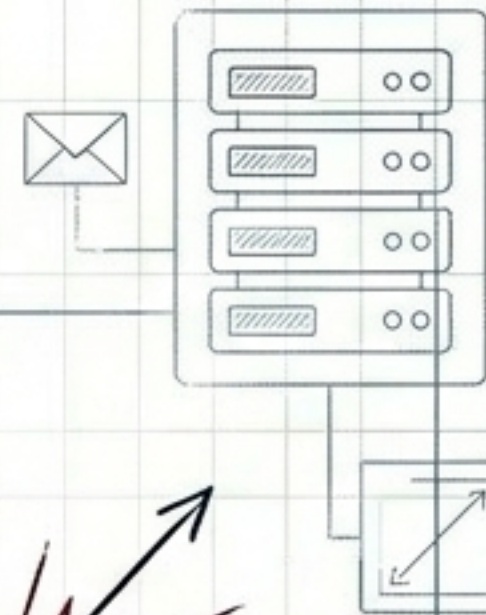
המכפיל העוצמתי: מתקפות הגברה והשתקפות (Amplification)

תוקפים משתמשים בשירותים פומביים כמראות שמגבירות את עוצמת התקיפה.

פקטורי הגברה (מתוך נתוני US-CERT):



• פרוטוקול Memcached: הגברה פסיכית של פי 50,000! (תוקן בגרסה 1.5.6, אך עדיין מסוכן במערכות ישנות).



התהליך:

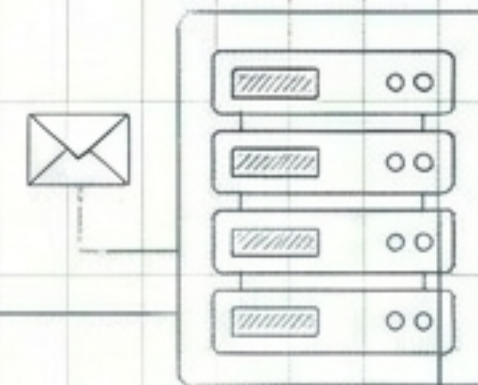
- התוקף שולח בקשה קטנה לשרת פומבי כשהוא מזייף את כתובת ה-IP של קורבן המטרה (Spoofing).
- השרת משיב לקורבן עם קובץ נתונים מוגדל פי כמה.



זוהי לוחמה אסימטרית: זריקת אבן קטנה שיוצרת מפולת שלגים עצומה.

ניצול פרוטוקולים: מתקפת SYN Flood

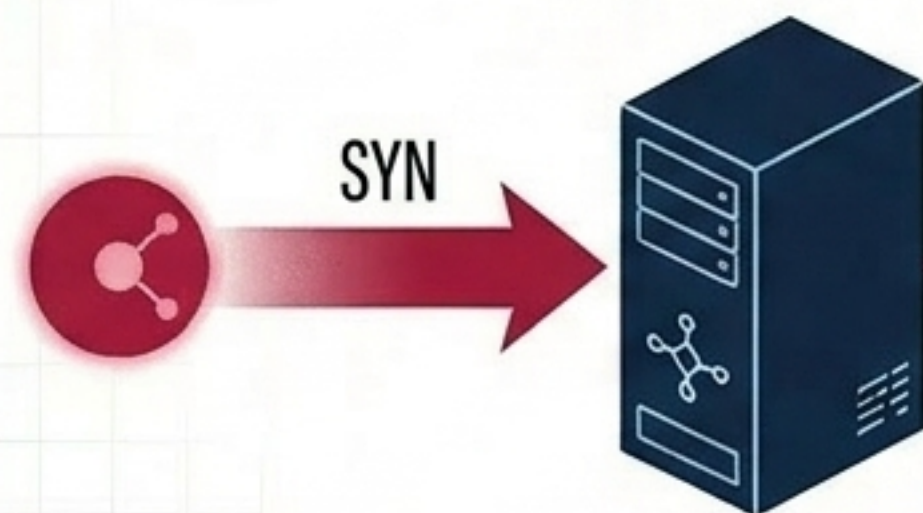
מתקפה זו מנצלת את תהליך לחיצת היד המשולשת (3-Way Hand3) של פרוטוקול ה-TCP.



1

1. הבקשה המזויפת:

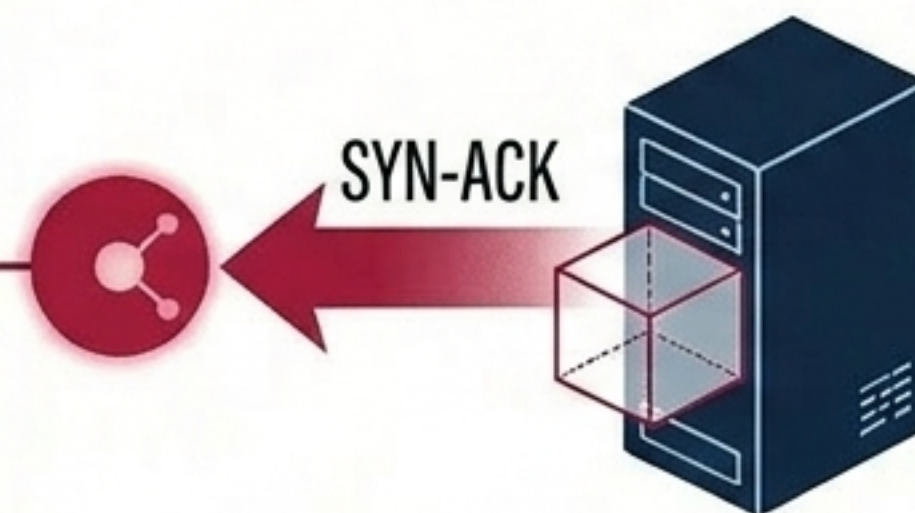
התוקף שולח מבול של בקשות חיבור (SYN) עם כתובות שולח מזויפות.



2

2. הציפייה:

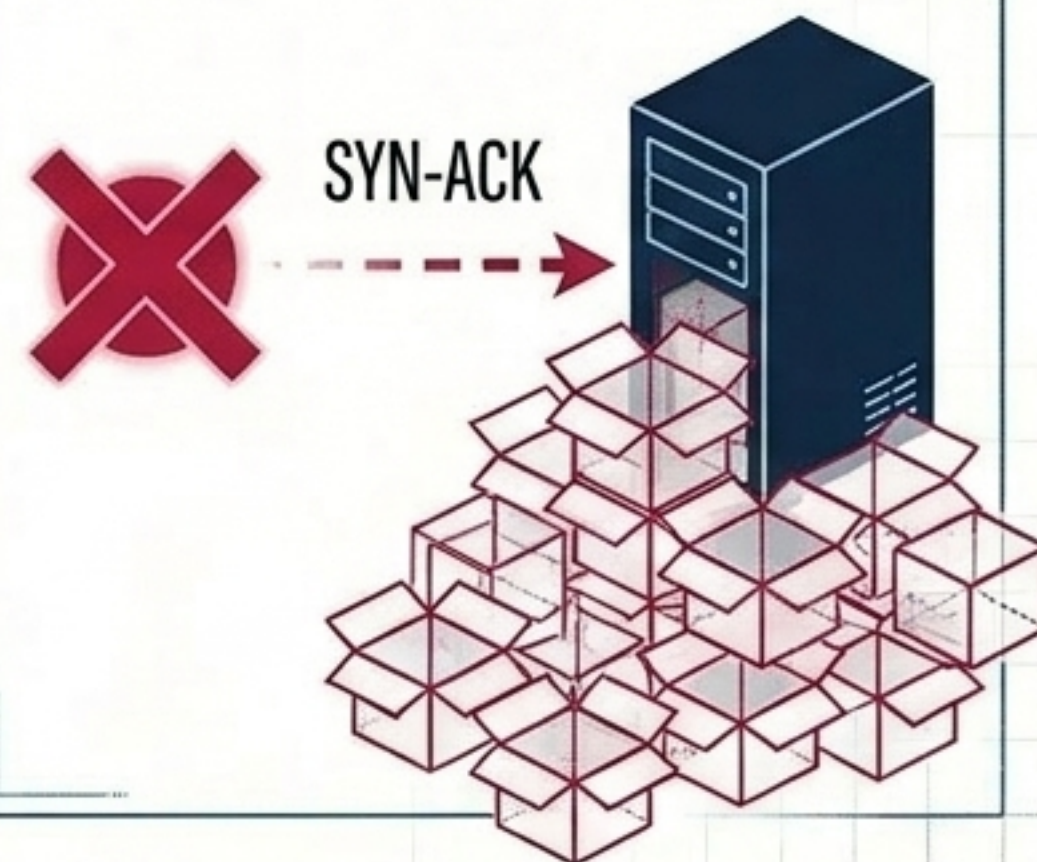
השרת מגיב לכל בקשה ב-SYN-ACK, מקצה משאבים לחיבור ממתין (חיבור פתוח-למחצה), וממתין לאישור הסופי.



3

3. הקריסה:

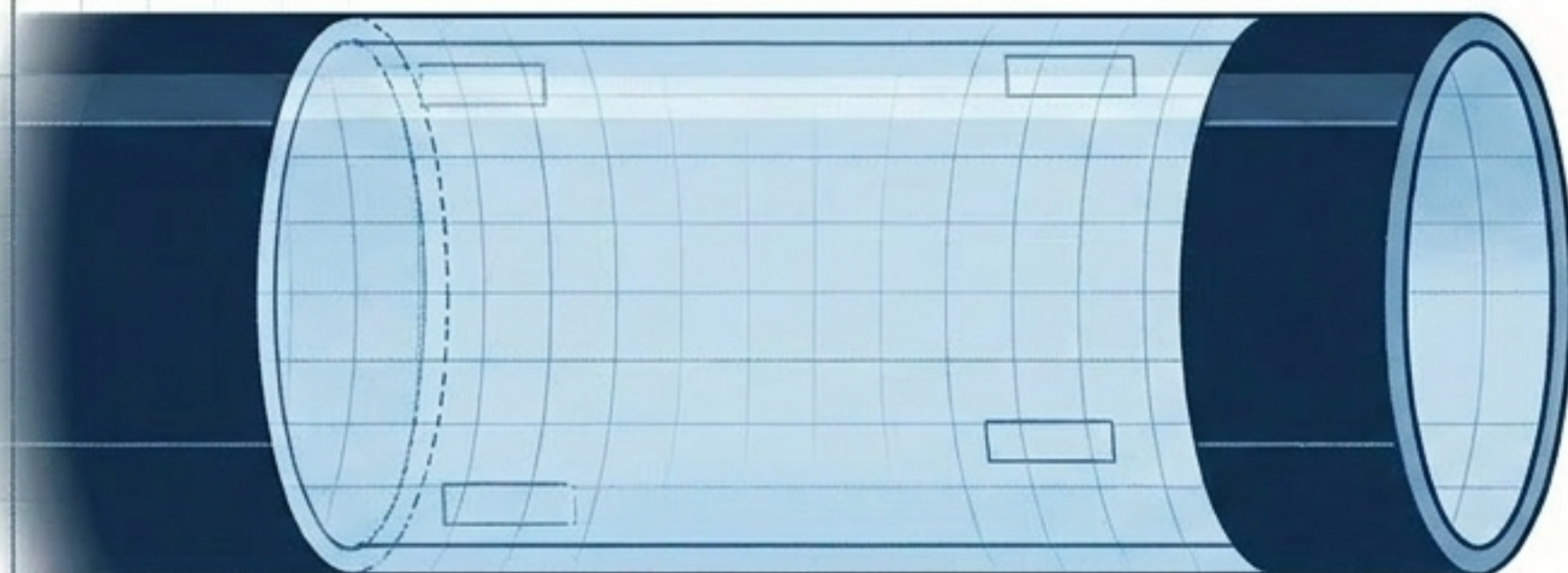
האישור הסופי (ACK) לעולם לא מגיע. התורים של השרת מתמלאים בחיבורי בחיאיים רפאים עד שאינו מסוגל לקבל בקשות ממשתמשים לגיטימיים.



שכבת היישום: גישת הצלף (HTTP Slow POST)

שלא כמו מתקפות רוחב פס, מתקפות שכבת היישום מתמקדות במשאבים לוגיים, והן נראות כמו תעבורה לגיטימית.

רוחב פס פנוי
(Unused Bandwidth)



מאגר חיבורי שרת
(Server Connection Pool)



קריסת חיבורים
(Connection Collapse)

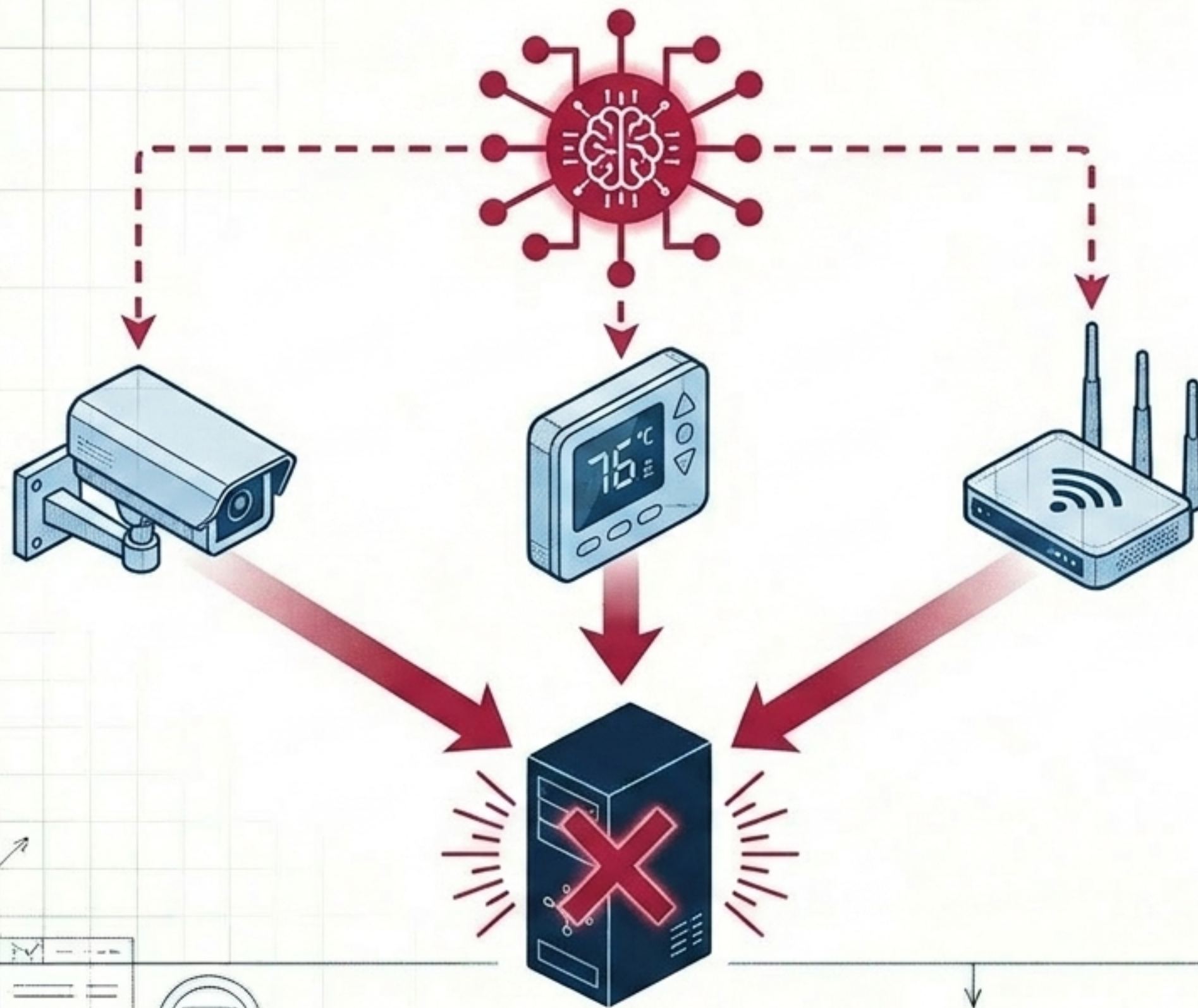
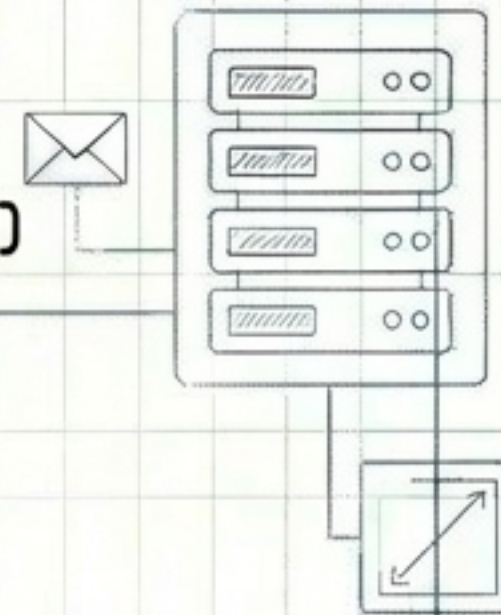


דוגמת ה-HTTP Slow POST (התגלה ב-2009):

- התוקף שולח כותרת HTTP תקינה לחלוטין המצהירה על גודל ההודעה.
- עם זאת, הוא מתחיל לשלוח את גוף ההודעה בקצב איטי להחריד (למשל: 1 בית בלבד כל 110 שניות).
- השרת, מתוך כוונה לציית לפרוטוקול, שומר את החיבור פתוח וממתין להשלמת ההודעה.
- התוקף פותח אלפי חיבורים כאלו. רוחב הפס נשאר פנוי לחלוטין, והמעבד אינו תחת עומס – אך מאגר החיבורים הפנויים של השרת קורס.

הארסנל המבוזר: בוטנטים ומכשירי IoT

כיום, התוקפים אינם מסתמכים על מחשבים מרכזיים, אלא משעבדים צבא של מכשירים חכמים תמימים שמוגדרים ברמת אבטחה נמוכה.

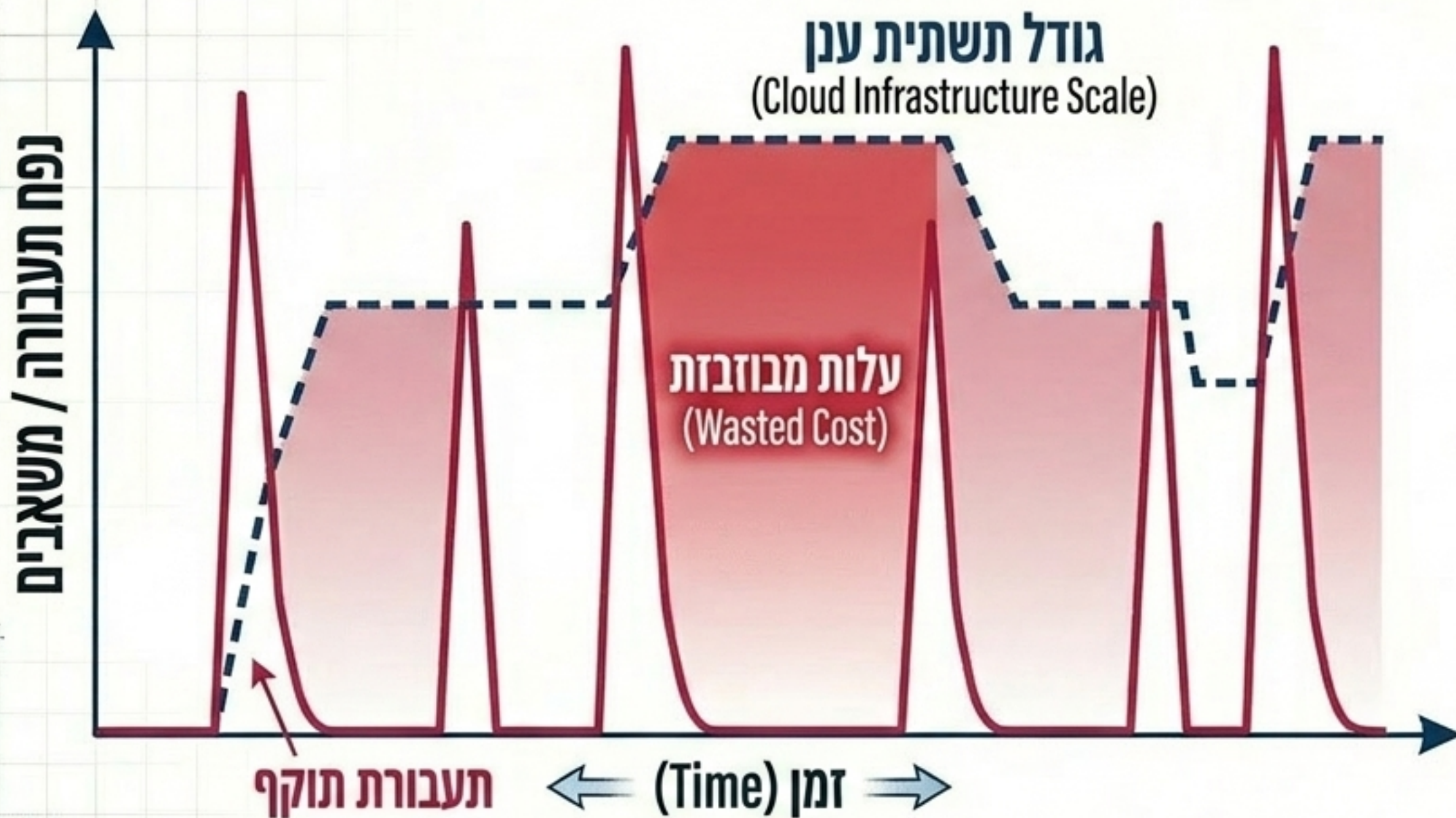
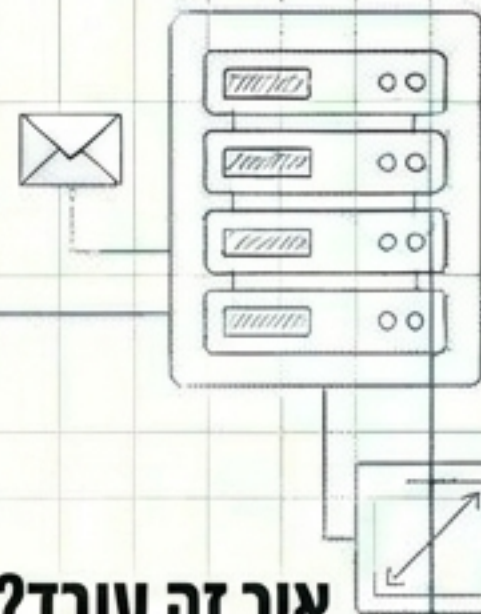


תופעת ה-Mirai Botnet:

- תולעת מחשבים שסרקה את הרשת במטרה לאתר מכשירי אינטרנט של הדברים (IoT) כגון מצלמות אבטחה (CCTV), שעונים חכמים ונתבים ביתיים.
- המשתמשים הביתיים כלל אינם מרגישים שהמכשיר שלהם נגוע ומשתתף בתקיפה.
- באוקטובר 2016, בוטנט Mirai הופעל נגד ספקית האינטרנט Dyn, מה שהוביל לקריסת הגישה לשירותי ענק כמו Netflix ו-Twitter למשך מספר שעות.

מתקפת היו-יו (Y_0-Y_0): הפיכת האלסטיות לנשק

מתקפה ייחודית המכוונת נגד אפליקציות מבוססות ענן המשתמשות במנגנון שינוי קנה-מידה אוטומטי (Autoscaling).



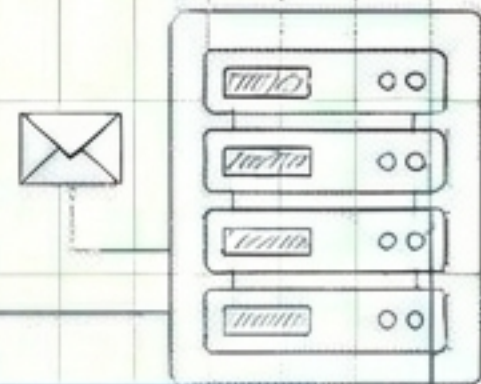
איך זה עובד?

- התוקף מייצר פרץ קצר ועוצמתי של תעבורה.
- תשתית הענן של הקורבן מזהה את העומס ומגדילה את המשאבים באופן אוטומטי (Scale-Up), מה שגורר עלויות כספיות ניכרות.
- התוקף מפסיק לפתע את התעבורה, מה שגורם למערכת להצטמצם בחזרה (Scale-Down).
- המחזור חוזר על עצמו שוב ושוב.

המטרה: לאו דווקא להקריס את השרת, אלא לייצר שחיקה תפעולית ולהסב הפסדים כספיים עצומים למפעיל האפליקציה בגין חשבונות ענן מנופחים.

מסחור האיום: DDoS כשירות וסחיטה רשתית

מתקפות DDoS הפכו לתעשייה ממוסדת הנגישה גם לאנשים ללא רקע טכני.



DDoS-as-a-Service / שירותי Booter/Stresser

SaaS

- פלטפורמות המוסוות ככלים לבדיקת עומסים מאפשרות לכל אדם לשכור בוטנט.

50 Gbit/s
Traffic capacity

Buy Now

- תעבורה טיפוסית נעה בין 5 ל-50 Gbit/s – די והותר כדי לנתק עסק קטן או משתמש פרטי, זוּם או משתמש פרטי, וזאת תמורת תשלום זעום באשראי או קריפטו.

Subject: Ransom Demand
From: Unknown Attacker

סחיטה כפולה:

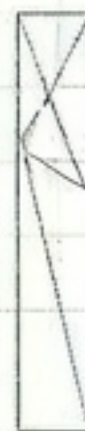
קבוצות פשיעה יוזמות מתקפה קלה (הדגמת כוח) ושולחות דרישת כופר בביטקוין, עם איום למתקפת ענק אם לא ישולם.

To: Target Organization

Send 0.5 BTC to the following address:
bc1qxy2kgdygjrsqtzq2n0yrf2493p83kkfjhx0wlh

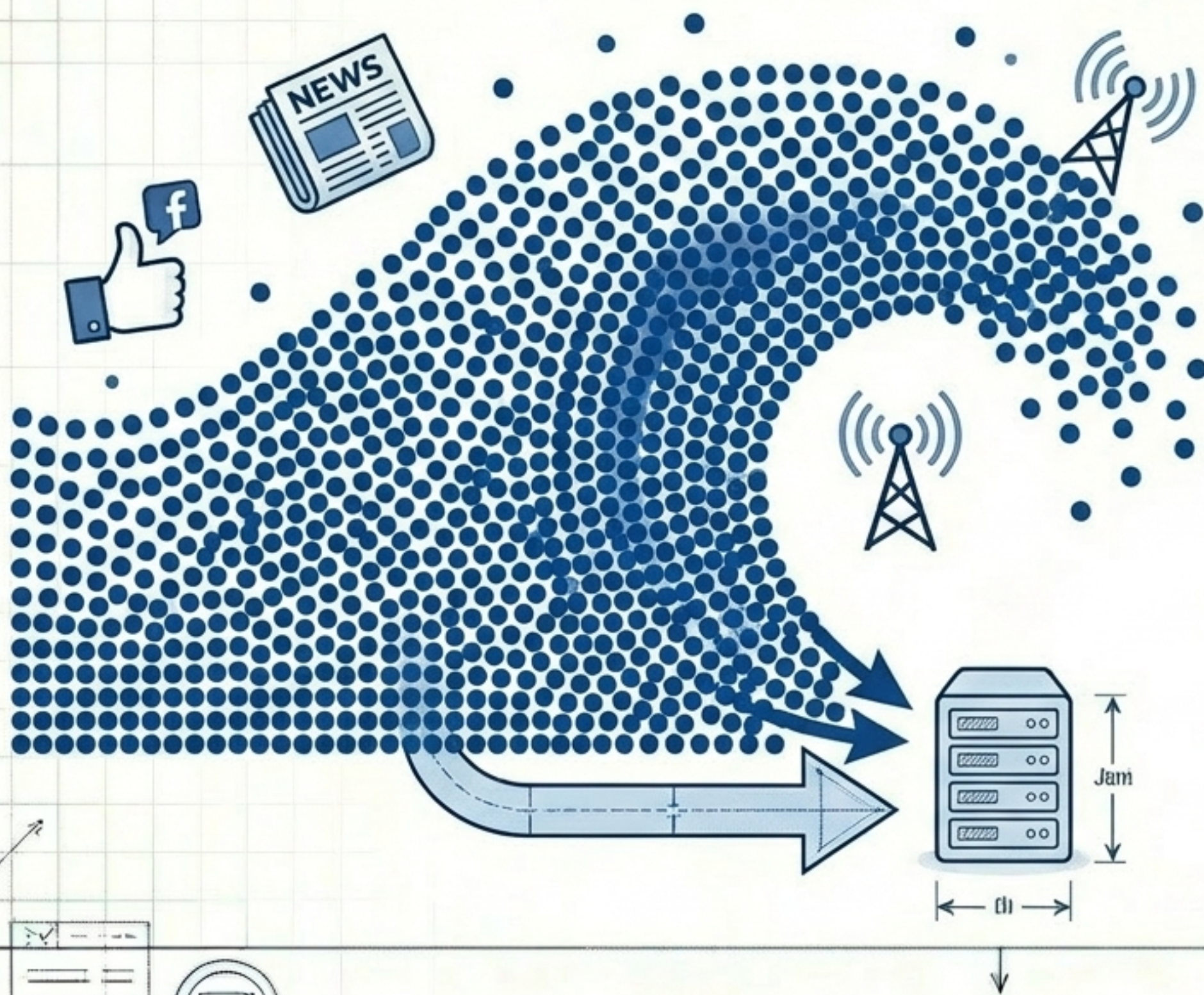
(לדוגמה: ביולי 2023 הותקף אתר A03 ונדרש לשלם כופר של \$30,000).

המלצת המומחים: לעולם אין לשלם.



מניעת שירות בלתי-מכוונת (Unintentional DoS)

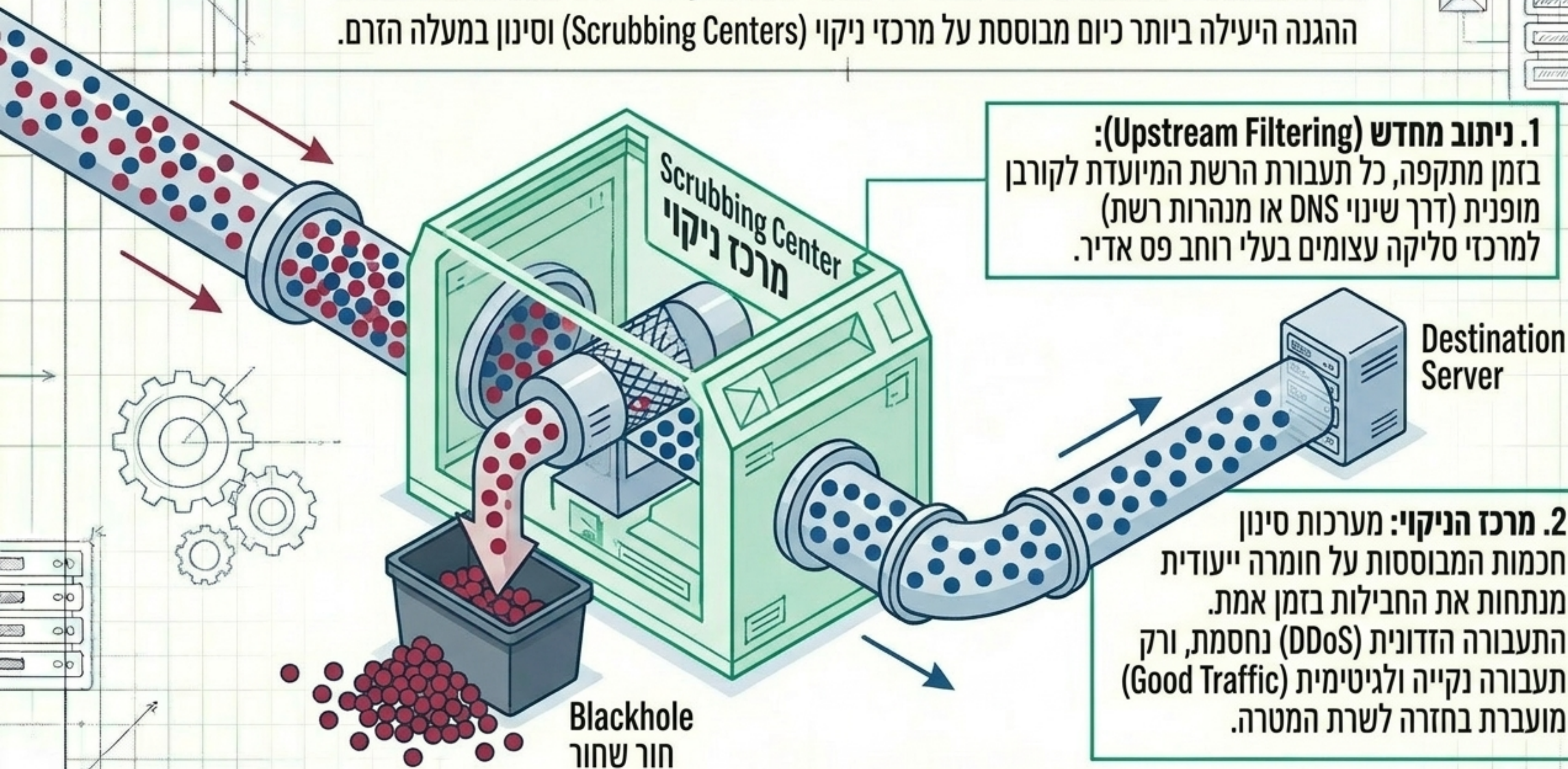
לא כל קריסת רשת נובעת מזדון. לעיתים קרובות, זינוק פתאומי ובלתי צפוי בפופולריות פועל בדיוק כמו מתקפת DDoS לכל דבר.



- **תופעת חיבוק המוות (Reddit Hug of Death)**
ואפקט ה-Slashdot: אתר חדשות קטן קורס תחת עומס של מאות אלפי כניסות לאחר שקיבל קישור מפלטפורמה עצומה.
- **אירועי מדיה היסטוריים:** עם מותו של מייקל ג'קסון ב-2009, הרשת העולמית כמעט וקרסה. מנועי חיפוש זיהו בטעות את עומס החיפושים הזיפושים החריג כווירוס או מתקפת סייבר.
- **אירועים אזוריים:** פלטפורמות ממשלתיות (כמו מפקדי אוכלוסין) שלא נערכו נכון לקצב כניסת משתמשים בזמן אמת.

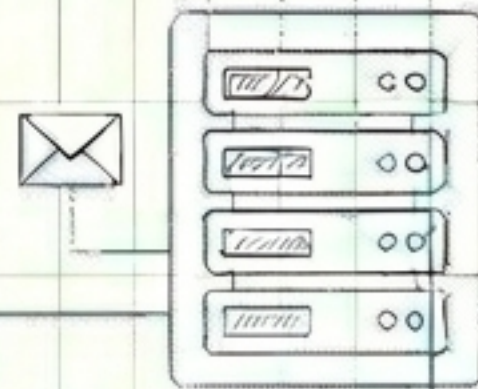
החומות והמסננים: כיצד התעשייה מתגוננת?

ההגנה היעילה ביותר כיום מבוססת על מרכזי ניקוי (Scrubbing Centers) וסינון במעלה הזרם.

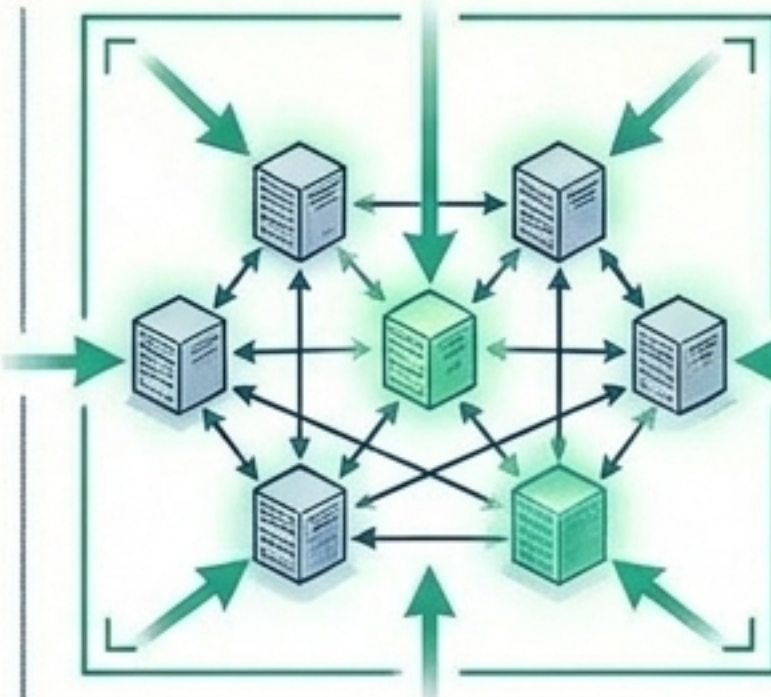


ארכיטקטורת מגן: טקטיקות עומק

הסתמכות על חומת אש מסורתית אינה מספיקה. הגנה רב-שכבתית דורשת מספר כלים:



• **ניתוב לחור שחור**
(Blackholing & Sinkholing):
הפניית כל התעבורה של יעד המותקף לחור שחור וירטואלי שמבטל את המנות (Packets) הרעות, פעמים רבות ברמת ספק האינטרנט.



• **רשת אניק* (Anycast Network):**
הפצת התעבורה על פני מספר נקודות גיאוגרפיות שונות ברחבי העולם, המפזרות את עומס ההתקפה ומונעות יצירת צוואר בקבוק.



• **מערכות מניעת חדירות מבוססות חומרה (ASIC IPS):**
חומרה ייעודית ומהירה במיוחד המנתחת אנומליות ופועלת כמו מפסק פחת (Circuit Breaker) אוטומטי המזהה התנהגות עוינת.



• **חסימת מבוססת פורטים ו-TTL:**
חסימת פורטים מסוימים (כגון חסימת פורט 1900 של UDP כדי למנוע השנקפות השתקפות SSDP) וסינון ערכי TTL חריגים שמעידים על כתובות IP מזויפות.

תוקף

תשתית ארגונית יקרה

סיכום: עידן ההתשה הכלכלית

מתקפות DDoS עברו טרנספורמציה. מהשחתת אתרים וקריסות שרתים, הן הפכו לנשק של התשה תפעולית ופיננסית.

התובנה המרכזית: האסימטריה המוחלטת. תוקף משתמש במאמץ ובגסוץ חטופים של צד שלישי (מצלמות אבטחה, שרתים פומביים) כדי לאלץ את הקורבן להוציא הון עתק על שירותי סליקת נתונים, חומרה מתקדמת, או חיובי ענן מנופחים בגין תעבורת סרק.

DDoS כיום אינו רק איום טכני על זמינות הנתונים – זהו איום קיומי ומסוחרר-עלויות על המודל העסקי של ארגונים במרחב הדיגיטלי. נדרשת ארכיטקטורה אלסטית ומוכנות פרואקטיבית מתמדת מול אויב מבוזר.